Incident Management and Response Policy

App: Time on the record (Zoom App)
Incident contact: danielbermudez6one9@gmail.com (also listed on the App's Support page)
Last reviewed: 2026-10-17 · **Review cadence:** at least every 12 months, and after every incident

1. Purpose and scope

Defines how security incidents affecting the App, its infrastructure, its secrets, or its users are detected, contained, resolved, and communicated.

A **security incident** is any confirmed or suspected event that compromises the confidentiality, integrity, or availability of the App or of data it processes. Examples:

- leaked Zoom client secret or webhook secret token;
- unauthorized access to the Zoom Marketplace or GitHub account;
- an exploited vulnerability in the App or a dependency;
- tampering with deployed code;
- a sustained denial of service.

2. Roles

The App owner is the incident lead and is responsible for every step below. Because the App is run by one person, the owner keeps this document and the contact list in §7 somewhere reachable even if the server is unavailable.

3. Severity levels

Level	Definition	Examples	Response start
SEV-1 Critical	Active compromise, or exposure of secrets or user data	Client secret leaked publicly; Zoom Marketplace or GitHub account taken over	Immediately, at most 4 hours
SEV-2 High	Exploitable vulnerability with no evidence of exploitation yet; service down	Critical CVE in a dependency; app unreachable in meetings	Within 24 hours
SEV-3 Low	Limited impact or theoretical risk	Low-severity scan finding; brief degradation	Within 5 business days (handled as a normal vulnerability)

4. Response process

4.1 Detect and report

Incidents may be detected through:

- server logs;
- Zoom notifications;
- scanner results;
- dependency advisories;
- user or researcher reports to the contact email.

Every report gets a reply within 2 business days.

4.2 Triage

The owner confirms whether an incident occurred, assigns a severity, and starts an incident log: a timestamped record of what was seen, decided, and done.

4.3 Contain

Typical containment actions:

- **Leaked or suspected-leaked secret:** regenerate the client secret and/or webhook secret token in the Zoom Marketplace, update the server's `.env` file, and restart the server. Because the App stores no OAuth tokens, rotating the client secret is enough to cut off any misuse of App credentials.
- **Compromised account:** change the password and revoke active sessions and API keys.
- **Exploited code or dependency:** take the App offline or roll back to the last known-good release, then patch.

4.4 Eradicate and recover

- Fix the root cause.
- Run the full verification suite: SAST, SCA and DAST, per the SSDLC.
- Reinstall dependencies from the lockfile (`npm ci`) and restart the server.
- Confirm normal operation in a live Zoom meeting.

4.5 Notify

- **Zoom:** for any SEV-1 incident, or any incident affecting Zoom users or Zoom credentials, notify Zoom through the Zoom App Marketplace developer support channel without undue delay, and **within 72 hours** of confirmation, or sooner where the Zoom Marketplace developer terms require it.
- **Affected users:** if personal data was affected, notify them without undue delay, and as required by applicable law (e.g. GDPR Art. 33/34, US state breach-notification laws), with:
    - what happened;

    - what data was involved;
    - what was done;
    - what they should do.
- **Data collected:** the App holds very little user data (transient meeting UUIDs and timer totals only; no tokens, names, or emails), which limits the scope of any data breach. Notification decisions are still made case by case.

4.6 Post-incident review

Within 14 days of closing a SEV-1 or SEV-2 incident, the owner writes a short review covering:

- timeline;
- root cause;
- what worked;
- what to change.

Follow-up actions are tracked to completion, and this policy is updated if needed.

5. Evidence preservation

Before making destructive changes during containment, save the relevant logs and a copy of the deployed version (the git commit hash), where it is safe to do so.

6. Testing

This plan is walked through as a tabletop exercise at least once a year, for example the scenario "the client secret was committed to a public repository". Gaps found are fixed in this document.

7. Contacts

Who	How
App owner (incident lead)	danielbermudez6one9@gmail.com
Zoom developer support	https://devsupport.zoom.us
GitHub (repository compromise)	https://support.github.com